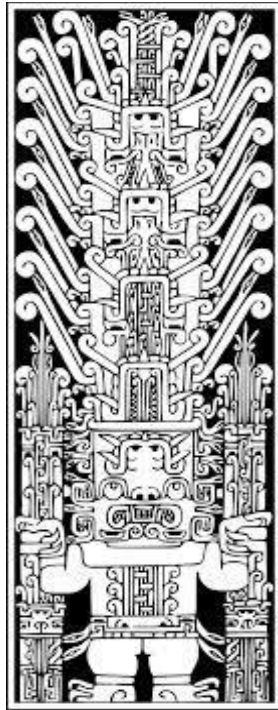

UNIVERSIDAD NACIONAL FEDERICO VILLARREAL
Facultad de Ingeniería Industrial y de Sistemas
Escuela Profesional de Sistemas



Phishing en Página Web

Informe de práctica — Simulación controlada de un ataque de ingeniería social

CURSO

Ciberseguridad

AUTOR

Aaron Mark Mina Rios

CÓDIGO

2021018505

Lima, Perú

2026

1. Introducción

Entre todas las técnicas de ingeniería social, el phishing sigue siendo, año tras año, una de las más rentables para un atacante: no requiere vulnerar un firewall ni explotar una falla de software, basta con explotar algo mucho más difícil de parchear, la confianza que un usuario deposita en la apariencia de una página que reconoce. Un logotipo familiar, un formulario de acceso que "se ve igual" y un enlace que llega en el momento oportuno suelen ser suficientes para que la víctima entregue, sin sospecharlo, sus credenciales.

El presente informe documenta una práctica controlada realizada en el marco del curso de Ciberseguridad, en la que se construyó una réplica visual de un sitio web legítimo con el propósito de evidenciar, de forma didáctica, qué tan sencillo resulta para un atacante inducir a un usuario a ingresar información sensible en un formulario falso. El ejercicio no buscó explotar ninguna vulnerabilidad técnica de la página original, sino reproducir su apariencia externa, que es precisamente el vector que el phishing aprovecha.

Toda la actividad se desarrolló dentro de un entorno de laboratorio cerrado, sin publicar el sitio simulado en internet ni recolectar credenciales reales de terceros. El objetivo fue exclusivamente académico: comprender el proceso de construcción de un ataque de este tipo para luego poder reconocerlo, prevenirlo y explicarlo con criterio técnico.

2. Planteamiento del problema

En la práctica diaria, la mayoría de usuarios valida la legitimidad de un sitio web a partir de señales puramente visuales: el logotipo corporativo, la paleta de colores institucional o la disposición de los menús. Rara vez se detienen a revisar el dominio exacto que aparece en la barra de direcciones, la validez del certificado HTTPS o los indicadores de seguridad que el propio navegador ofrece de forma gratuita.

Esa brecha entre lo que el usuario percibe y lo que realmente debería verificar es, en el fondo, el problema que este informe busca ilustrar. Un atacante no necesita replicar el backend de una organización, únicamente su fachada: con eso alcanza para montar una página clonada capaz de capturar credenciales u otro tipo de información sensible sin que la víctima lo note en el momento.

De ahí surge la necesidad de realizar una simulación controlada que permita observar, paso a paso, cómo se arma un ataque de phishing y qué elementos —tanto técnicos como de comportamiento del usuario— permiten a una persona capacitada detectarlo a tiempo.

3. Objetivos

3.1 Objetivo general

Demostrar, mediante una simulación controlada, el proceso de construcción de un ataque de phishing basado en la réplica visual de un sitio web legítimo.

3.2 Objetivos específicos

- Elaborar una réplica visual de un sitio web legítimo con fines demostrativos.
- Identificar los elementos visuales que un atacante suele reproducir con mayor frecuencia: logotipo, formulario de acceso y estructura de menús.
- Analizar los indicadores de seguridad que permiten distinguir un sitio legítimo de uno falso.

- Concientizar sobre la importancia de verificar la URL y el certificado HTTPS antes de ingresar credenciales.

4. ¿Qué hace efectivo a un ataque de phishing?

Antes de entrar al detalle de la práctica, conviene situar el ataque dentro de su lógica completa. Un ataque de phishing rara vez se agota en la página falsa: es una cadena de pasos donde cada eslabón depende del anterior. El diagrama siguiente resume, de forma simplificada, ese recorrido, desde que el atacante prepara la réplica hasta que las credenciales capturadas terminan usándose para acceder a una cuenta real.

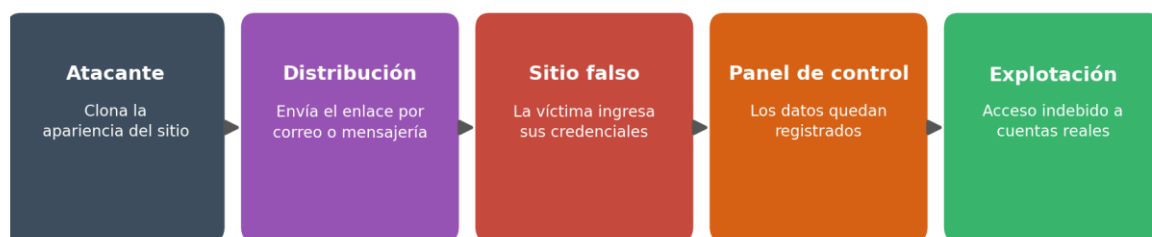


Figura 1. Cadena típica de un ataque de phishing, desde la clonación del sitio hasta la explotación de las credenciales obtenidas.

Este esquema es útil porque muestra que el punto débil no está solo en la tecnología: está repartido entre un sitio que engaña visualmente y una persona que, al no verificar, termina completando el ataque por el atacante. Con esa idea en mente, la siguiente sección detalla cómo se reprodujo ese primer eslabón —la réplica visual— en el ejercicio de laboratorio.

5. Desarrollo de la práctica: réplica visual del sitio web

La finalidad de esta etapa fue demostrar cómo un atacante podría replicar visualmente un sitio web legítimo para inducir a los usuarios a ingresar información sensible, evidenciando de paso la importancia de verificar la autenticidad de una página antes de proporcionar credenciales o datos personales.

Para la simulación se elaboró una página de prueba con una apariencia muy similar a la del sitio legítimo evaluado. La réplica reprodujo, de forma deliberada, los elementos que un usuario normalmente asocia con la "identidad visual" de la organización:

- El diseño general de la página, incluyendo colores y disposición de secciones.
- El logotipo corporativo.
- La estructura visual del formulario de acceso.
- La distribución de menús e imágenes públicas del sitio original.

Para lograr una réplica convincente se trabajó directamente sobre la estructura de la página original, ajustando el encabezado, el menú de navegación y el formulario de acceso hasta que el resultado fuera visualmente indistinguible a primera vista. Las siguientes capturas muestran el resultado de la página de prueba elaborada durante el ejercicio:

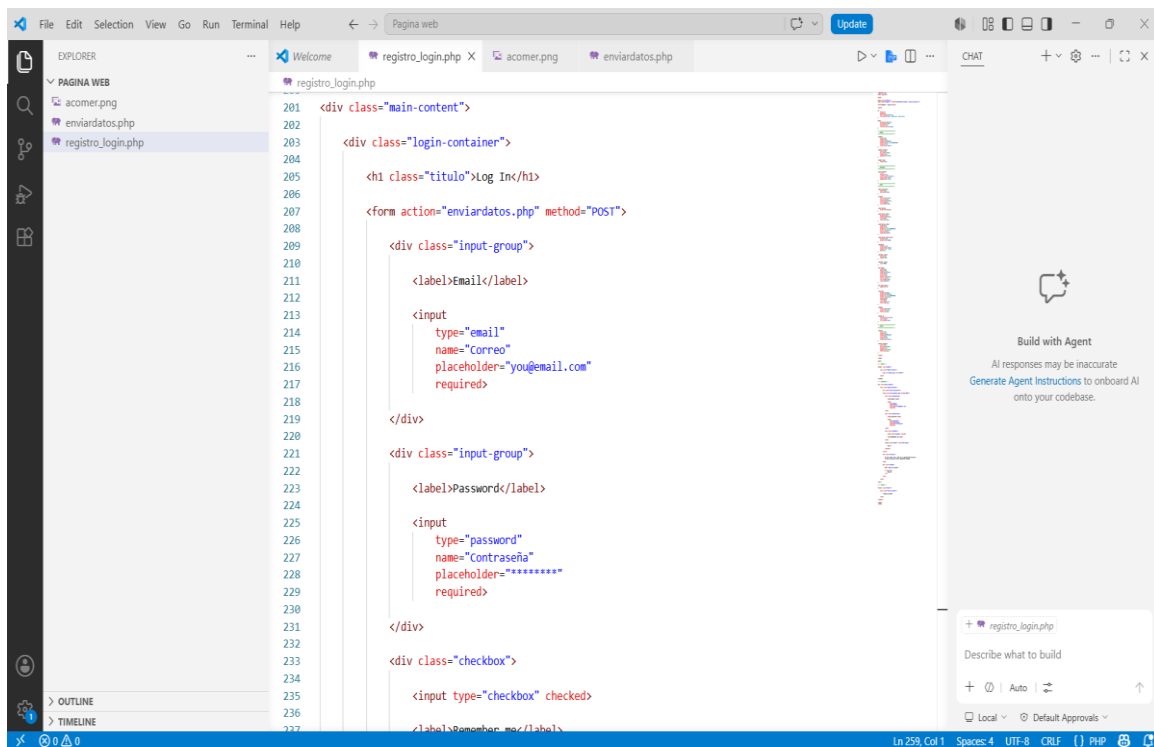


Figura 2. Vista general de la página de prueba, con el encabezado y el menú de navegación replicados.

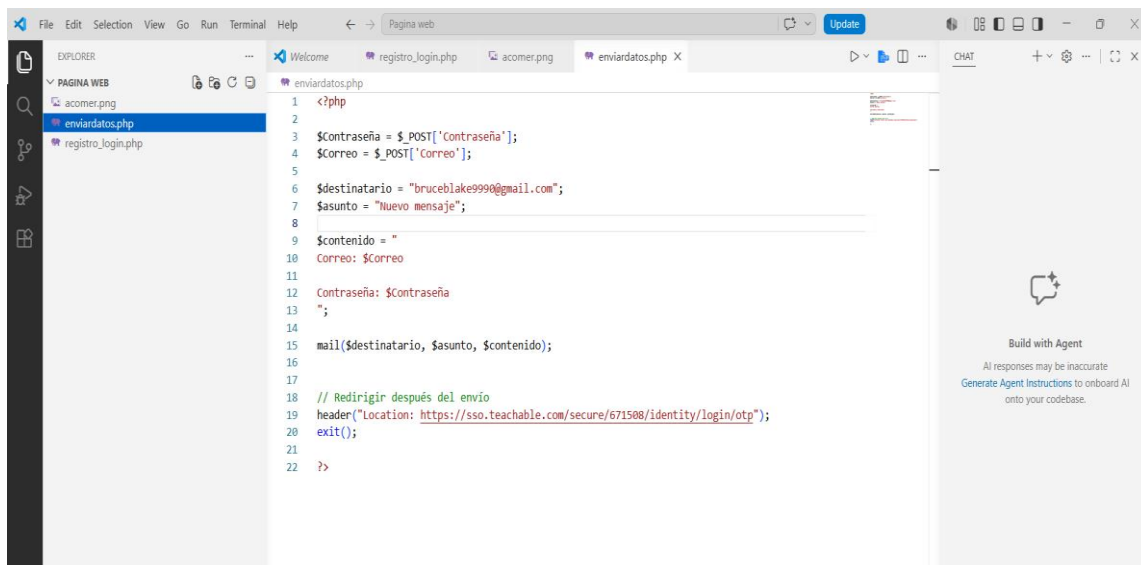


Figura 3. Formulario de acceso de la página falsa, elaborado para imitar el diseño del formulario original.

5.1 Comparación visual entre el sitio real y la réplica

Una vez ajustada la estructura general y el formulario de acceso, se procedió a comparar ambos sitios lado a lado. El ejercicio permite apreciar qué tan poco margen de diferencia visual percibe un usuario que no se detiene a revisar la URL o el certificado del sitio:

Página real

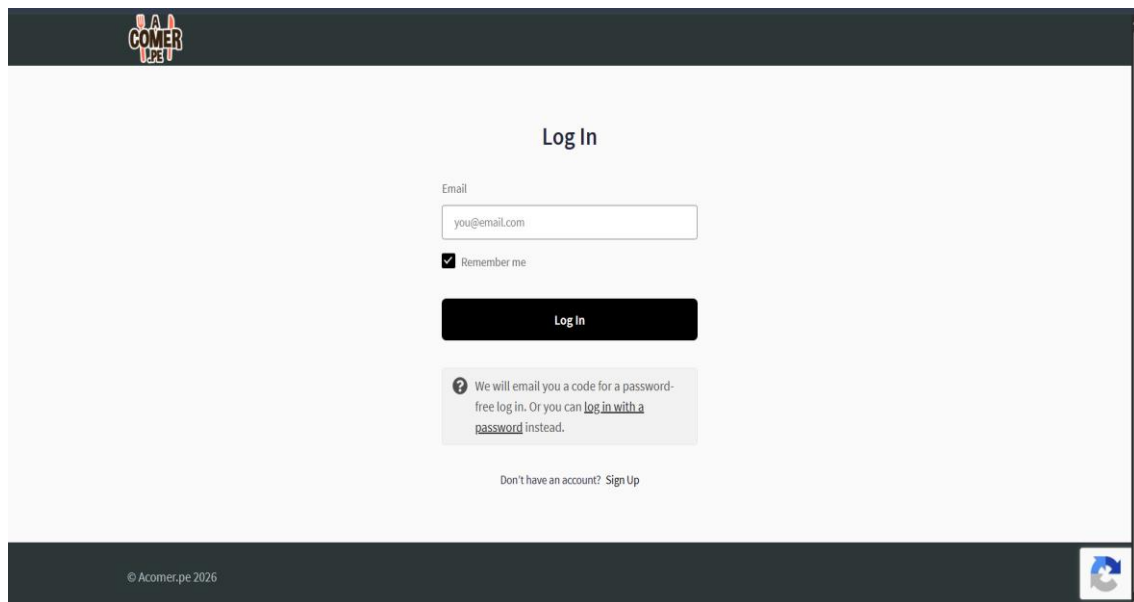


Figura 4. Sitio web legítimo utilizado como referencia para la réplica.

Página falsa (réplica)

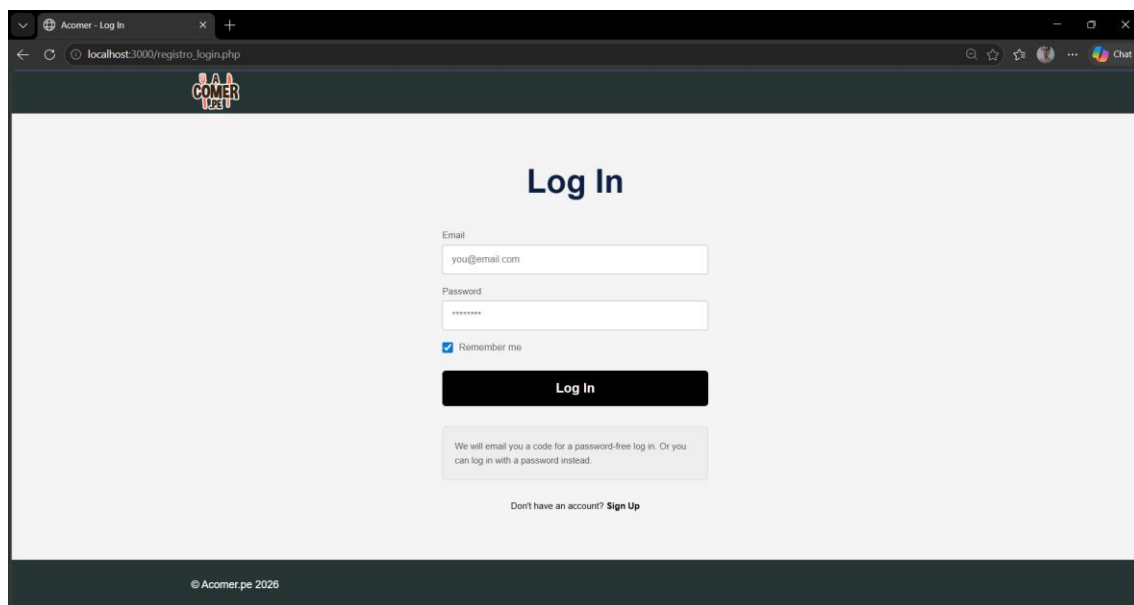


Figura 5. Réplica elaborada para la simulación, visualmente equivalente al sitio original.

5.2 Resultados de esta etapa

Durante la simulación se confirmó que una página visualmente similar es capaz de generar confianza en usuarios que no verifican de forma activa aspectos de seguridad como:

- La dirección URL real del sitio web.
- La presencia de un certificado HTTPS válido.
- El dominio oficial de la organización.
- Los indicadores de seguridad que el propio navegador muestra.

Esto confirma que el phishing continúa siendo una de las técnicas más efectivas para obtener credenciales, no porque explote una falla del sistema, sino porque explota un hábito de verificación que casi nadie practica de forma consistente.

6. Herramienta utilizada para el despliegue del sitio simulado

Para alojar y gestionar la página de phishing dentro del entorno de laboratorio se utilizó una herramienta orientada a la generación de sitios de prueba con fines de concientización en ciberseguridad, ampliamente empleada en cursos y certificaciones de seguridad ofensiva para fines exclusivamente educativos. A continuación se documenta, con fines descriptivos, el proceso general de instalación y ejecución dentro del entorno controlado de Kali Linux.

```
git clone https://github.com/htr-tech/zphisher.git
```

Figura 6. Instalación de la herramienta dentro del entorno de pruebas de Kali Linux.

```
bash zphisher.sh
```

Figura 7. Ejecución de la herramienta y levantamiento del servicio local encargado de alojar la página simulada.

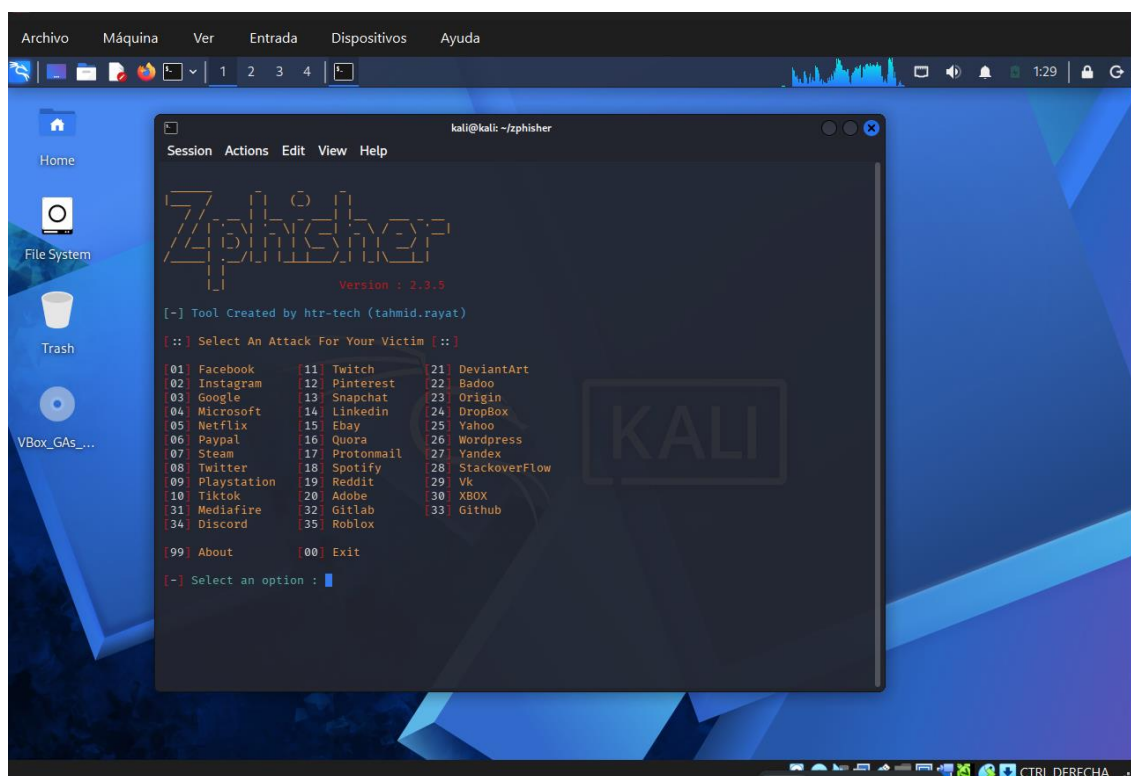


Figura 8. Menú de configuración desplegado tras la ejecución de la herramienta.

6.1 Análisis de resultados

Tras la ejecución, la herramienta desplegó un menú de configuración que permitió seleccionar la plantilla del sitio a replicar y generar un enlace temporal, accesible desde fuera del entorno local. Este comportamiento simula la forma en que un atacante real distribuiría el enlace: por correo electrónico, mensajería instantánea o redes sociales, apoyándose casi siempre en algún pretexto de urgencia para reducir el tiempo de análisis de la víctima.

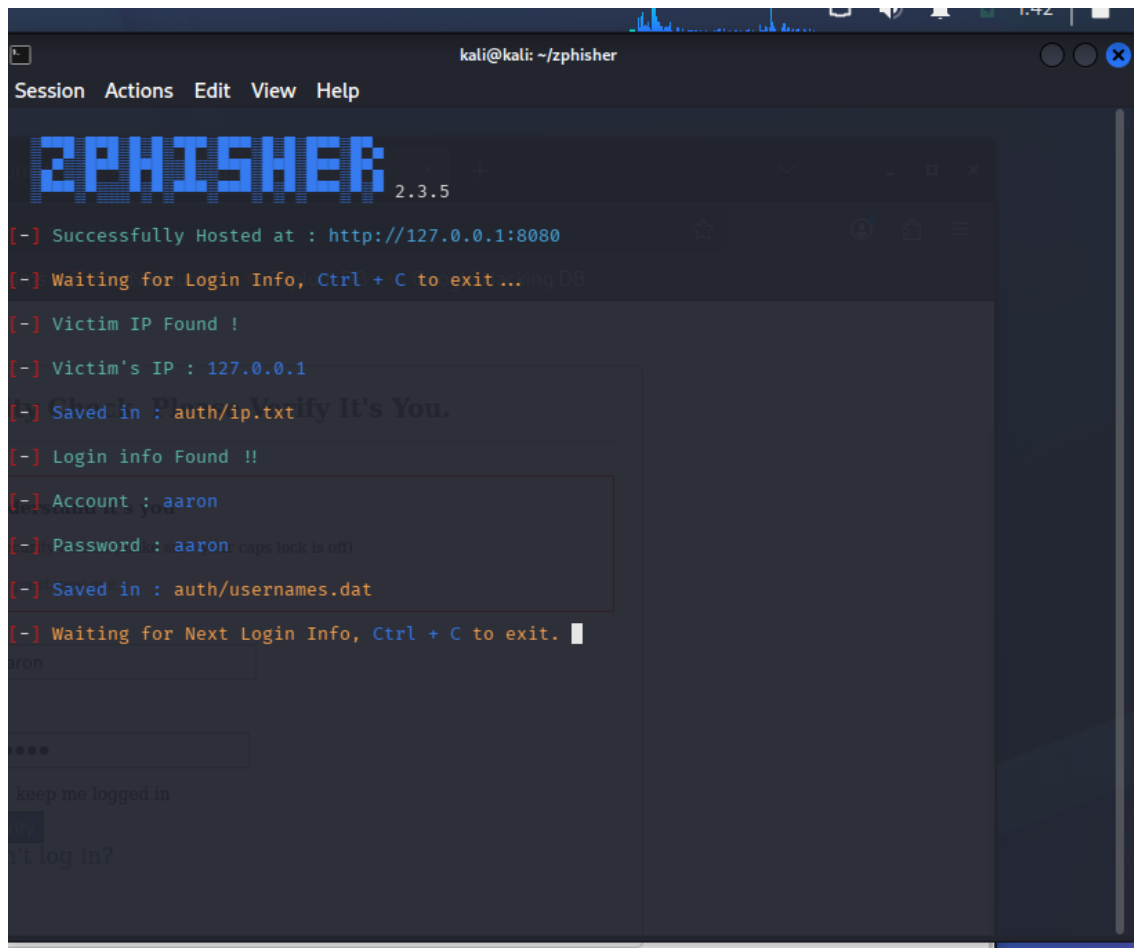


Figura 9. Enlace temporal generado por la herramienta, listo para ser distribuido en el escenario simulado.

El enlace generado redirige a la víctima hacia la página clonada. Cualquier credencial ingresada en el formulario de prueba queda registrada en el panel de control de la herramienta, sin que el sitio legítimo se vea afectado en ningún momento del ejercicio.

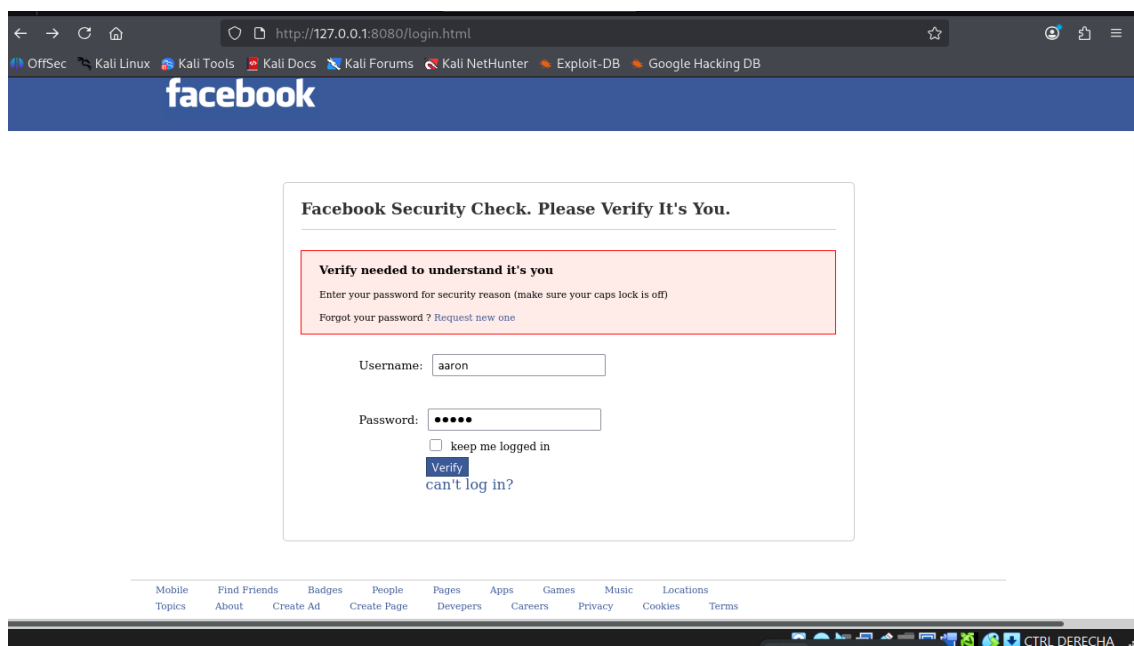


Figura 10. Panel de control mostrando el registro de las credenciales ingresadas en el entorno de prueba.

7. Interpretación de los resultados

Lo que este resultado deja en evidencia no es tanto una debilidad técnica como una brecha de comportamiento: con herramientas de acceso público y sin necesidad de conocimientos avanzados de desarrollo web, es posible desplegar un sitio de phishing plenamente funcional en cuestión de minutos. La combinación de una réplica visual convincente con un enlace de distribución rápida constituye un vector de ataque de bajo costo y alto impacto, especialmente cuando la víctima no revisa el dominio, el certificado HTTPS ni el remitente del enlace recibido.

Esto refuerza una idea central del curso: la defensa contra el phishing no depende únicamente de controles técnicos como filtros de correo o listas de dominios bloqueados, sino también, y en buena medida, de la capacidad del usuario final para detenerse un segundo antes de escribir sus credenciales.

7.1 Riesgo asociado

- Robo de credenciales de acceso a cuentas personales o corporativas.
- Suplantación de identidad y acceso no autorizado a sistemas internos.
- Propagación de la campaña de phishing a través de las cuentas ya comprometidas.
- Daño reputacional para la organización cuyo sitio fue suplantado.

8. Recomendaciones

A partir de lo observado en la práctica, se plantean las siguientes recomendaciones, orientadas tanto al usuario final como a la organización:

- Verificar siempre el dominio exacto y la validez del certificado HTTPS antes de ingresar credenciales, sin confiar únicamente en la apariencia de la página.
- Habilitar autenticación multifactor (MFA) en todas las cuentas críticas, de modo que una credencial filtrada no sea suficiente para comprometer el acceso.
- Capacitar periódicamente a los usuarios en la identificación de correos y enlaces sospechosos, reforzando hábitos de verificación más que reglas memorizadas.
- Implementar filtros antiphishing y soluciones de seguridad de correo electrónico a nivel corporativo, como primera barrera antes de que el enlace llegue al usuario.
- Establecer canales oficiales de verificación (por ejemplo, un correo o número de soporte conocido) para que el usuario pueda confirmar la legitimidad de un mensaje sospechoso antes de actuar.

9. Conclusión

La práctica confirmó, en un entorno controlado, algo que las estadísticas de incidentes vienen repitiendo desde hace años: el phishing sigue siendo efectivo no por su sofisticación técnica, sino por lo poco que cuesta explotar la confianza visual del usuario. Construir la réplica no exigió vulnerar ningún sistema, solo reproducir una apariencia; y ese es, precisamente, el punto que este informe buscaba dejar claro para su discusión académica: la primera línea de defensa contra el phishing no está en el servidor, está en el hábito de verificación de quien recibe el enlace.